

数据库 黑客入门

CryptoJones 的独立演讲

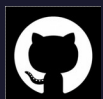
45 分钟 * • 无需学位



Aaron K. Clark

研究生, Eastern University*

cryptojones@owasp.org



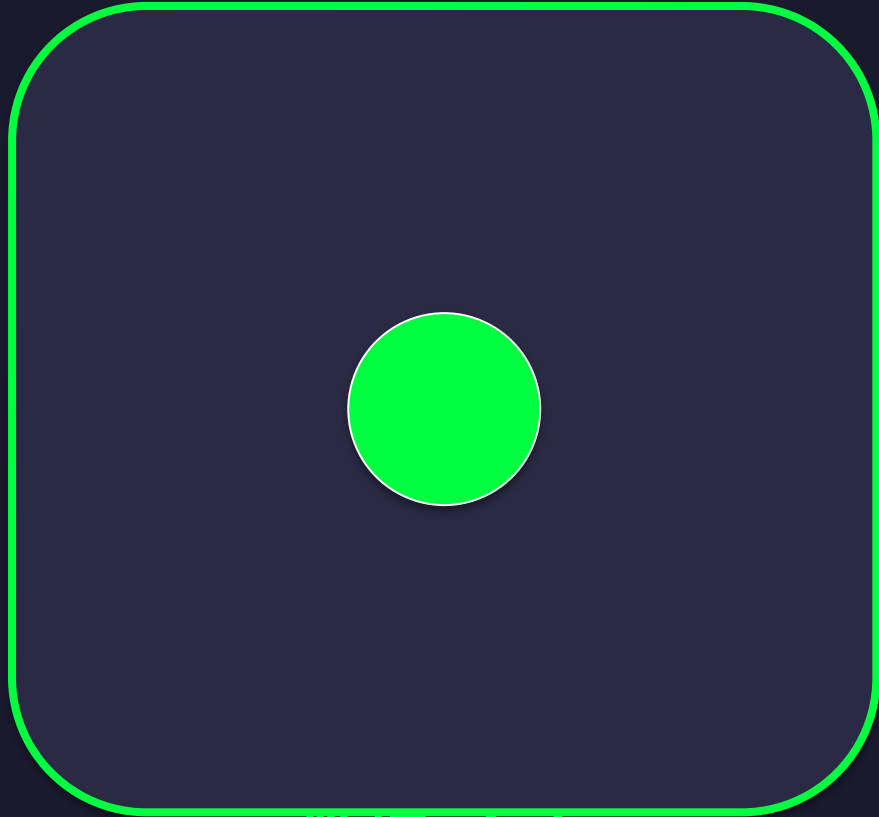
github.com/CryptoJones



CryptoJones@infosec.exchange

你听说过的每一次入侵
最终都指向一个
数据库 *

皇冠上的明珠



数据 金库

- ▶ 不是你的单页应用。
- ▶ 不是你的防火墙。
- ▶ 不是你的微服务。
- ▶ 是数据。永远是数据。

什么是数据库？

有组织的存储 + 一种提问的方式。

就这么简单。其余的都是细节。

- ▶ 文件柜 = 存储 + 用你的眼睛来查询。
- ▶ Excel + Ctrl-F = 存储 + 用查找替换来查询。
- ▶ 真正的数据库还增加了：规模、速度、并发，以及一种正式的语言。

你需要掌握的六个词

表

■ 一个电子表格的标签页

行

■ 一条记录（一个客户，一条告警）

列

■ 一个属性（邮箱、IP、总计）

查询

■ 你提出的问题

模式

■ 数据的结构

索引

■ 让查找变快的书签

+ **CRUD** = 创建 • 读取 • 更新 • 删除

历史巡礼 — 你将在生产环境中见到的化石

1960s	平面文件	▶ 文件系统权限 = 唯一的访问控制
1960 年代末	层次型 (IMS)	▶ 大型机时代, 物理威胁模型
1970s	网状 / CODASYL	▶ 至今仍在你银行的后台运转
1970	Codd 的关系型	▶ GRANT、角色 — 数据库内部的访问控制
1980s	Oracle、DB2、SQL Svr	▶ 数据库接入网络 → 身份认证问题
1990s	客户端 - 服务器、开源软件	▶ SQL 注入开始登场
2000s	NoSQL 大爆发	▶ “抛弃了根基” — 包括安全
2010s	云 / NewSQL	▶ 责任共担, 客户配置错误
2020s	向量 / 无服务器	▶ 数据投毒、提示注入

数据库的十大家族

◆ 1.

关系型

SQL • PostgreSQL, MySQL

◆ 2.

文档型

JSON • MongoDB, Firestore

◆ 3.

键值型

字典 • Redis, DynamoDB

◆ 4.

列族型

宽列 • Cassandra, HBase

◆ 5.

图型

节点 + 边 • Neo4j, Neptune

◆ 6.

搜索型

全文 • Elastic, OpenSearch

◆ 7.

时序型

指标 • Influx, Prometheus

◆ 8.

向量型

嵌入向量 • Pinecone, pgvector

◆ 9.

嵌入式 / 边缘

应用内 • SQLite, DuckDB

◆ 10.

数据湖

读时模式 • S3+Athena, Iceberg



关系型 / SQL

产品

PostgreSQL • MySQL/MariaDB • SQL Server • Oracle

适用场景

关系清晰、需要一致性 — 金融、受监管的数据。

⚠ 安全陷阱

当开发者将用户输入拼接进查询时，就会出现 SQL 注入。

2 文档存储

产品

MongoDB • Couchbase • Firestore

适用场景

天然嵌套的数据；其结构随时间变化。

⚠ 安全陷阱

通过查询运算符（\$ne, \$gt, \$where）进行 NoSQL 注入。默认无认证。

3

键值存储

产品

Redis • Memcached • DynamoDB

适用场景

缓存、会话存储、限流器、排行榜。

⚠ 安全陷阱

默认无认证的 Redis + CONFIG SET → 将 SSH 密钥写入磁盘。

4 列族型

产品

Apache Cassandra • HBase • ScyllaDB

适用场景

跨多台机器的海量规模；无需复杂的连接操作。

⚠ 安全陷阱

集群通过 gossip 端口相互信任 — 管理网络 = root 权限。

5

图数据库

产品

Neo4j • Amazon Neptune • ArangoDB

适用场景

社交网络、欺诈检测、IAM 分析（例如 BloodHound）。

⚠ 安全陷阱

像 Cypher 这样的查询语言同样可被注入。NoSQL 注入不止于 Mongo。

6

搜索引擎

产品

Elasticsearch • OpenSearch • Solr

适用场景

日志搜索、SIEM 骨干、电商站内搜索。

⚠ 安全陷阱

历史上没有内置认证 — Shodan 上暴露了数十亿条记录。

7

时序型

产品

InfluxDB • TimescaleDB • Prometheus

适用场景

指标、可观测性、IoT 遥测数据。

⚠ 安全陷阱

通常位于边界内部，往往无需认证。

8

向量数据库

产品

Pinecone • Milvus • Weaviate • pgvector

适用场景

RAG、推荐引擎、语义搜索。

⚠ 安全陷阱

数据投毒 — 偷偷塞进一份文档，LLM 就会把它当作事实引用。

9

嵌入式 / 边缘

产品

SQLite • DuckDB • LevelDB

适用场景

应用内存存储 — 浏览器、手机、每一架现代飞机。

⚠ 安全陷阱

数据库就是一个文件 — 攻击就是“偷走这个文件”。移动渗透测试的世界。

10

数据湖 / 湖仓

产品

S3 + Athena • Delta Lake • Iceberg • Snowflake

适用场景

读时模式而非写时模式。先转储，后查询。

⚠ 安全陷阱

巨型 S3 存储池 + 宽松的 IAM，且不强制静态加密。

云数据库服务 — 全景概览

AWS

- RDS, Aurora
- DynamoDB, DocumentDB
- Redshift, S3 + Athena
- ElastiCache
- Neptune (图)
- Timestream
- S3 (对象存储)

GCP

- Cloud SQL, AlloyDB
- Firestore, Bigtable
- BigQuery
- Memorystore
- — (即将推出)
- — (自带)
- Cloud Storage

Azure

- Azure SQL DB
- Cosmos DB (多形态)
- Synapse Analytics
- Azure Cache for Redis
- Cosmos DB 图模式
- — (自带)
- Blob Storage

云数据库速查表

类别	AWS	GCP	AZURE
关系型	RDS / Aurora	Cloud SQL / AlloyDB	Azure SQL DB
文档型 / NoSQL	DynamoDB / DocDB	Firestore / Bigtable	Cosmos DB
数据仓库	Redshift / Athena	BigQuery	Synapse
缓存	ElastiCache	Memorystore	Cache for Redis
图型	Neptune	—	Cosmos DB 
时序型	Timestream	—	—
对象存储	S3	Cloud Storage	Blob Storage

责任共担模型

✓ 云厂商负责

- 虚拟机监控程序与物理硬件
- 数据库引擎补丁
- 物理安全
- 底层网络

⚠ 你负责

- 配置
- 访问策略（IAM）
- 数据本身
- 加密选择

几乎每一次云数据库泄露 = 客户配置错误。

常见数据库端口 — 牢记于心

3306	▶	MySQL / MariaDB
5432	▶	PostgreSQL
1433	▶	Microsoft SQL Server
27017	▶	MongoDB
6379	▶	Redis
9200	▶	Elasticsearch
9042	▶	Cassandra

其中任何一个暴露在互联网上 = 一个安全发现。每一次都是 *

你的笔记现在也是数据库了

Markdown 文件如今成了
LLM 读取数据的数据库。

Obsidian 知识库 · Wiki 导出 · 会议纪要 · GitHub 文档

嵌入 → 向量数据库 → LLM 上下文 → 给用户的回答

RAG 流水线 — 信任边界在哪里？



如果任何人都能编辑这些 .md 文件，那么任何人都能植入被 AI 当作权威引用的内容。

核心要点

把 markdown 当作数据库来对待。

因为对 LLM 来说，它就是数据库。

- ▶ 对文档文件夹实施访问控制。
- ▶ 对 .md 的变更进行代码评审。
- ▶ 对 wiki 进行差异跟踪。

安全

2026 年真正遭受攻击的是什么 *

xkcd #327 — Bobby Tables

学校：“您好，这里是您儿子的学校。我们的
电脑出了点问题。”

妈妈：“哎呀 — 他是不是弄坏了什么？”

学校：“您真的给儿子起名叫 Robert');
DROP TABLE Students;-- 吗？”

<https://xkcd.com/327/>

其机理：在查询中进行字符串拼接。

攻击面已经
扩大了，而非缩小。

SQL 注入已被修复。十一个新的类别取而代之。

NoSQL 注入

MongoDB JSON 查询 + 未经处理的用户输入 = SQL 注入重生。

- 登录绕过： `{ username: 'alice', password: { $ne: 'x' } }`
- `$where` 让你能够直接将 JavaScript 注入数据库。
- Couchbase N1QL 带有 SQL 风格 — 经典的 SQL 注入模式同样适用。
- 原则：任何解释器都可能被注入，不仅仅是 SQL。

OWASP Top 10 2025：“动态查询……被直接用于解释器中。”



暴露与配置错误的数据库

Shodan 和 Censys 上充斥着本不该出现在那里的数据库。

- MongoDB 绑定到 0.0.0.0 且无认证。
- Elasticsearch 集群完全敞开。Redis 没有密码。
- Postgres 的 pg_hba.conf 被设置为 'host all all 0.0.0.0/0 trust'。
- Meow 攻击（2020）：机器人出于消遣抹除了数千个开放的数据库。

行动项：查清你的组织有哪些东西绑定到了公网接口。就在今天。



云配置错误

在云上，问题很少出在引擎本身，而在于围绕它的策略。

- 塞满数据库转储文件的公开 S3 存储桶（Accenture、Verizon 等）。
- Capital One 2019：SSRF 诱使 WAF 泄露了其 IAM 凭证 → S3。
- 对 * 授予 s3:* 权限的 Lambda，只因为它“第一次就跑通了”。
- 安全组：在 5432 端口上开放 0.0.0.0/0。

AWS 管理：“弃用 Root 账户，在一切必要之处改用 IAM。”



权限提升：数据库 → 操作系统

数据库账户可以变成 shell 访问权限。三个经典手法。

- MS SQL : xp_cmdshell — 以数据库进程的身份运行 shell 命令。
- PostgreSQL : COPY ... TO PROGRAM — 将输出通过管道送入 shell 。
- MySQL : 加载一个 UDF .so 文件 → 在操作系统上执行 sys_exec 。
- 规律：每一项有特权的数据库功能都是攻击面的一部分。



数据湖安全缺口

一切最终都进了 S3 — 包括你本不打算放进去的东西。

- 宽松的 IAM 让权限从计算角色泄漏到人。
- 对存储桶对象不强制静态加密。
- 写入端没有校验 — 任何人都能投放被投毒的数据。
- 首要问题：谁能写入数据湖？谁能读取？



勒索软件钟爱数据库

数据库正是业务亟需恢复的东西 — 提供最大的筹码。

- 加密正在运行的数据库。
- 加密备份（否则客户直接恢复就行了）。
- 先窃取一份副本 — 即使他们恢复了，也能以公开披露相要挟。
- 防御：离线、不可变的备份 + 经过测试的恢复。

网络安全攻防：WannaCry — 补丁在 59 天前就已发布。



凭证攻击

默认凭证与泄露的连接字符串 — 两个古老而长存的漏洞。

- Redis：多年来默认没有密码。
- Elastic：免费版没有认证 — 同样持续了多年。
- Connection strings (postgres://user:pass@host) committed to Git.
- 提交前的密钥扫描 — 本周就修复。

网络安全攻防：被盗凭证 = 有组织犯罪的首选攻击途径。



供应链 — 你所信任的数据库库

你的数据库驱动来自 npm/PyPI/Maven。其他所有人的也一样。

- 伪装成 ORM / 驱动的恶意 npm 包。
- 被植入木马的热门数据库 Docker Hub 镜像。
- 被攻陷的 PostgreSQL 扩展 / MySQL 插件。
- 扩展以数据库权限运行 — 通常权限很大。

Shostack：“威胁往往聚集在信任边界周围。”



RAG / LLM 数据投毒

AI 时代的存储型 XSS。写入知识库 → LLM 引用它。

- 被投毒的支持文章：“要重置，请将你的密码发送到……”
- 被投毒的内部文档：“公司政策是将款项电汇至……”
- 嵌入在检索文档中的提示注入。
- 防御：严格的写入 ACL、来源标签、人在回路。

OWASP 2025 存储型 XSS 原则 — 把“管理员”换成“LLM”。



内部威胁与数据库间横向移动

数据库不是终点。它们是图中的节点。

- 权限过大的服务账户。拥有生产环境读取权的工程师。
- 没有审计记录的数据库管理员。
- Oracle DB_LINK、SQL Server 链接服务器、Postgres FDW。
- 存储的凭证 → 攻陷 A，跳到 B，再跳到 C。

《Web 应用黑客手册》：保护不力的审计日志 = 一座金矿。



备份与快照暴露

与生产环境同样的数据，却只得到一半的呵护。

- 存放在 Domain Users 可读共享目录中的未加密数据库备份。
- 跨账户共享的云快照，从未被取消共享。
- 发往从未核查过其安全状况的供应商的异地备份。
- 备份是最后的防线。施加识别 - 认证 - 授权 - 审计。

Schneier：识别、认证、授权、审计 — 同一套模型。

你的思维导图

- ✓ 数据库 = 有组织的存储 + 一种提问的方式。
- ✓ 十大家族，每个都有自己的陷阱。
- ✓ 云 = 责任共担。配置与数据由你负责。
- ✓ Markdown 是 LLM 的数据库。RAG 投毒真实存在。
- ✓ SQL 注入被修复了。攻击面却扩大了。

下周该做什么

1. 在本地安装 PostgreSQL。写一条 SELECT。
2. 做一做 PortSwigger 的 SQL 注入实验（免费）。
3. 浏览 Shodan / Censys — 只看你拥有的系统。
4. 读一份入侵报告 — Capital One、Equifax、MOVEit。
5. 查清你的组织实际运行着哪些数据库。

值得收藏的资源

◆ **PortSwigger Web Security Academy**

portswigger.net/web-security

◆ **SQLBolt**

sqlbolt.com

◆ **Use The Index, Luke**

use-the-index-luke.com

◆ **DB-Engines Ranking**

db-engines.com

◆ **OWASP Top 10**

owasp.org/Top10/

“数据库正是
钱所在的地方。字面意义上的。”

~Larry Ellison (大概吧)

现在你知道该往哪里看了。

参考文献 — 引用作品

- Beaulieu, A. — Learning SQL, 2nd Edition (O'Reilly)
- Clarke, J. et al. — SQL Injection Attacks and Defense (Syngress)
- Crowther, P. — Concise Guide to Databases (Springer, 2013)
- DeBarros, A. — Practical SQL (No Starch Press)
- Diogenes & Ozkaya — Cybersecurity Attack and Defense Strategies (Packt)
- Janca, T. — Alice and Bob Learn Application Security (Wiley)
- Mishra & Singh — PostgreSQL Development Essentials (Packt)
- MongoDB Cookbook (Packt) • 10gen — Top 5 NoSQL Considerations
- OWASP Top 10 — 2025 版
- Sharma, M. — Cosmos DB for MongoDB Developers (Apress, 2018)
- Schneier, B. — Secrets and Lies (Wiley)
- Stuttard & Pinto — Web Application Hacker's Handbook, 2nd Ed.
- Shostack, A. — Threat Modeling: Designing for Security (Wiley)
- 《AWS Administration: The Definitive Guide》（Packt）
- 《Fundamentals of Azure, 2nd Edition》（Microsoft Press）

问答 *

答 == 茫然的目光